

Information Security Management System for GreenGrid Energy

Master's in Computer Engineering - Cybersecurity and Systems
Administration
Security Management Systems (SIGSEG)

ISEP INSTITUTO SUPERIOR
DE ENGENHARIA DO PORTO

Students:

1200720@isep.ipp.pt

1201346@isep.ipp.pt

1200920@isep.ipp.pt

Contents

1	GreenGrid Energy: Organizational Overview	1
1.1	Introduction	1
1.1.1	Project Team Structure and Individual Responsibilities	1
1.1.2	Collective Responsibilities	2
1.1.3	Forward-Looking Objectives	2
1.2	Governance and Leadership	3
1.3	Key Departments	4
1.3.1	Engineering & Grid Operations	4
1.3.2	Research & Development Department	6
1.3.3	Customer Services & Billing	7
1.3.4	Supply Chain Management Department	7
1.3.5	Human Resources (HR)	8
1.3.6	Legal & Administration	8
1.4	Infrastructure and Security Context	9
1.4.1	Core Technologies and Systems	9
1.4.2	Network Topology	9
1.4.3	Threat Landscape	9
1.4.4	Technology and Department Association	10
2	Scope of the ISMS	11
2.1	Scope of the Information Security Management System (ISMS)	11
2.1.1	Organizational Stakeholders	11
2.1.2	Shared Information Technology (IT) Infrastructure and Systems	12
2.1.3	Business Processes, Data, and Security Risks by Department	12
2.1.4	ISMS Boundaries and Exclusions	13

List of Figures

1.1	Organizational chart of GreenGrid Energy	3
1.2	Organizational chart of Supply Chain Management Department	8

Acronyms

APTs	Advanced Persistent Threats
AWS	Amazon Web Services
CEO	Chief Executive Officer
CFO	Chief Financial Officer
CIO	Chief Information Officer
CISO	Chief Information Security Officer
COO	Chief Operating Officer
CTO	Chief Technology Officer
DER	Distributed Energy Resources
ERP	Enterprise Resource Planning
HR	Human Resources
ISMS	Information Security Management System
IT	Information Technology
IDS	Intrusion Detection System
IPS	Intrusion Prevention System
IoT	Internet of Things
NIST	National Institute of Standards and Technology
OT	Operational Technology
PII	Personally Identifiable Information
RD	Research & Development
SCADA	Supervisory Control and Data Acquisition
CRM	Customer Relationship Management
LAN	Local Area Network

OT	Operational Technology
VPN	Virtual Private Network
AD	Active Directory
MFA	Multi-factor Authentication

Chapter 1

GreenGrid Energy: Organizational Overview

1.1 Introduction

GreenGrid Energy is a large-scale enterprise³ specialized in renewable energy, with particular expertise in smart grid technology. The company employs approximately 400 professionals and has achieved revenues of around 35 million euros in the latest fiscal year. Its business activities are structured around three core revenue streams:

1. Smart grid infrastructure deployment (45%),
2. Renewable energy supply contracts (40%),
3. Energy monitoring and analytics software (15%).

With the expanding adoption of renewable energy solutions and increasing integration of Internet of Things (IoT) devices, GreenGrid Energy operates at the intersection of Operational Technology (OT) and IT. This convergence necessitates a comprehensive cybersecurity approach, robust governance frameworks, and specialized departmental oversight.

To effectively respond to these challenges, GreenGrid Energy has assembled a dedicated project team to assess and strengthen information security practices within critical departments, while collaboratively addressing overall cybersecurity objectives.

1.1.1 Project Team Structure and Individual Responsibilities

The project team is composed of three specialists, each focusing on securing a critical area of operation:

Research & Development (RD)

Inês Ribeiro (1201346@isep.ipp.pt) assesses and enhances security practices within the RD department, safeguarding proprietary technologies, algorithms, and intellectual property. She ensures secure collaborative environments for technology pilot programs, mitigating risks from industrial espionage and cyber threats.

Supply Chain Management

Manuela Leite (1200720@isep.ipp.pt) is responsible for analyzing procurement processes, supplier security standards, and component lifecycle management. Her primary focus includes establishing guidelines to mitigate risks associated with third-party vendors, particularly regarding hardware integrity and supply-chain vulnerabilities.

Customer Services & Billing

Eduardo Sousa (1200920@isep.ipp.pt) evaluates procedures related to customer onboarding, billing systems, and contract management, emphasizing the protection of Personally Identifiable Information (PII) and financial data. He coordinates closely with the Legal & Administration department to ensure regulatory compliance and prevent fraud.

1.1.2 Collective Responsibilities

Beyond their individual roles, the team collaborates on key areas that affect multiple departments, including:

- **Engineering & Grid Operations:** Ensuring secure integration of emerging technologies, particularly within OT and IT networks, to maintain operational integrity.
- **Human Resources:** Implementing role-based access control and promoting a security-aware culture through employee training and awareness programs.
- **Legal & Administration:** Aligning departmental activities with legal and regulatory requirements, managing compliance frameworks, and streamlining incident reporting mechanisms.
- **Cybersecurity Strategy Development:** Creating comprehensive security policies, incident response plans, and risk mitigation frameworks applicable organization-wide.

1.1.3 Forward-Looking Objectives

The project team's strategic objectives include:

1. Conducting comprehensive risk assessments to identify critical assets, vulnerabilities, and potential impacts across departments.
2. Implementing an ISMS aligned with recognized international frameworks (such as ISO 27001 or NIST CSF).
3. Ensuring secure convergence and seamless integration between OT and IT infrastructures.
4. Fostering a proactive security culture emphasizing continuous improvement and awareness throughout the organization.

1.2 Governance and Leadership

GreenGrid Energy follows a governance model that balances strategic oversight with efficient operations:

- **Board of Directors:** Define strategic vision, approves major investments, and ensures compliance with energy sector regulations.
- **Chief Executive Officer (CEO):** Oversees day-to-day operations and reports directly to the Board.
- **Executive Management Team:**
 - *Chief Financial Officer (CFO):* Handles budget planning, financial compliance, and resource allocation.
 - *Chief Technology Officer (CTO):* Determines technological direction, including research initiatives and product development.
 - *Chief Operating Officer (COO):* Manages core operations, covering engineering, supply chain, and service delivery.
 - *Chief Information Officer (CIO):* Aligns IT strategy with business objectives and oversees IT infrastructure.
 - *Chief Information Security Officer (CISO):* Develops cybersecurity strategies and enforces best practices across OT and IT domains.
- **Department Directors or Managers:** Lead their respective divisions and report to the relevant C-level executive.

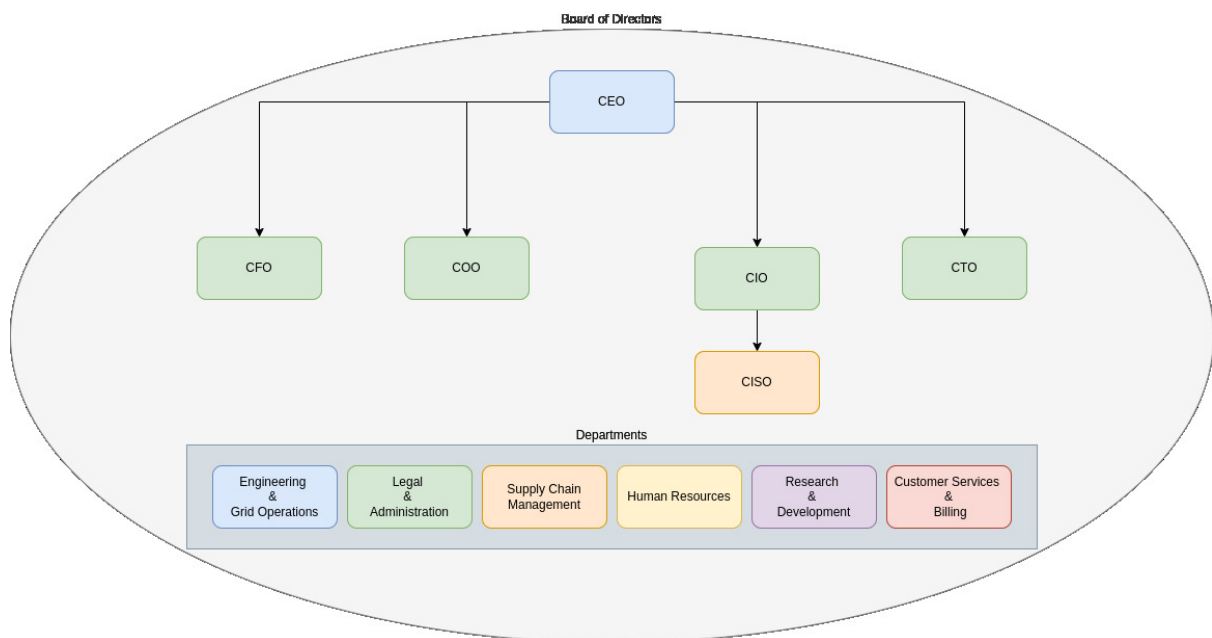


Figure 1.1: Organizational chart of GreenGrid Energy

Figure 1.1 provides an overview of the organization's structure. Each department has a dedicated director, while the executive team members focus on their respective areas of

expertise. Together with the CEO and department directors, these executives form the Board of Directors. All major decisions—including governance matters and the scope of new or revised policies—must be approved by this governing body before implementation throughout the company and its individual departments.

1.3 Key Departments

GreenGrid Energy employs a total of 400 staff members. Of these, 12 serve in leadership roles across the Board of Directors and C-level positions, leaving 388 employees distributed among the following six core departments. Each department is led by a Director or Manager, who reports to the relevant executive.

1.3.1 Engineering & Grid Operations

The Engineering & Grid Operations department at GreenGrid Energy is responsible for designing, maintaining, and optimizing the physical power distribution network. This includes real-time monitoring of energy flow, grid stability, and operational efficiency. The department plays a critical role in integrating renewable energy sources into the smart grid infrastructure while ensuring compliance with regulatory standards.

Core Responsibilities

The department's key responsibilities include:

- **Grid Infrastructure Management:** Overseeing the deployment, maintenance, and upgrades of smart grid components, including substations, transmission lines, and Distributed Energy Resources (DER).
- **Supervisory Control and Data Acquisition (SCADA) System Operations:** Ensuring continuous monitoring and control of grid assets using SCADA systems to maintain grid stability and prevent outages.
- **Grid Security and Reliability:** Implementing resilience measures to protect against cybersecurity threats, natural disasters, and system failures.
- **OT Security:** Managing the convergence of IT and OT environments by deploying security controls for grid-connected devices and industrial control systems.
- **Incident Response and Disaster Recovery:** Developing contingency plans to mitigate risks associated with grid failures, cyberattacks, and supply chain disruptions.
- **Integration of Renewable Energy:** Managing the technical challenges of incorporating solar, wind, and other renewable energy sources into the smart grid.

Infrastructure and Technology Stack

The Engineering & Grid Operations department relies on the following core technologies:

- **SCADA Systems:** Used for real-time monitoring and control of critical grid components.

- **IoT Sensors and Smart Meters:** Providing detailed performance data from field assets to optimize energy distribution.
- **Edge Computing:** Enabling localized data processing for low-latency decision-making.
- **Hybrid Cloud Platforms (AWS/Azure):** Supporting predictive analytics, system automation, and secure data storage.
- **Firewall and Intrusion Detection System (IDS)/Intrusion Prevention System (IPS) Solutions:** Ensuring network security through robust threat detection mechanisms.
- **OT/IT Network Segmentation:** Implementing strict security controls to prevent unauthorized access between corporate IT and operational networks.

Departmental Management Structure

The Engineering & Grid Operations department is led by an **Engineering & Grid Operations Manager**, who reports directly to the COO. The internal structure is organized as follows:

- **Engineering & Grid Operations Manager:** Provides strategic oversight, ensures grid stability, and aligns department objectives with company goals.
- **Grid Infrastructure Lead:** Oversees grid modernization projects, substation maintenance, and infrastructure expansion efforts.
- **SCADA and Control Systems Specialist:** Manages SCADA operations, ensuring continuous monitoring, control, and security of grid systems.
- **OT Security Engineer:** Focuses on securing grid-connected assets and mitigating cyber threats targeting operational technology.
- **Renewable Energy Integration Specialist:** Ensures seamless incorporation of renewable energy sources, optimizing grid balancing and energy distribution.
- **Field Operations Supervisor:** Coordinates on-site maintenance teams, ensuring safety compliance and operational efficiency in power distribution.

Risk Management and Cybersecurity Challenges

The Engineering & Grid Operations department faces multiple cybersecurity challenges, including:

- **Cyber Threats to Grid Infrastructure:** Nation-state actors and Advanced Persistent Threats (APTs) targeting critical infrastructure.
- **Vulnerabilities in IoT Devices:** Ensuring the security of smart meters and edge devices against unauthorized access and data breaches.
- **Supply Chain Risks:** Preventing hardware and software tampering during procurement and deployment.

- **Data Integrity Risks:** Protecting SCADA and real-time operational data from manipulation or corruption.

To address these challenges, the department follows a structured risk management framework, incorporating ISO 27001 and National Institute of Standards and Technology (NIST) Cybersecurity Framework guidelines.

Future Strategic Initiatives

The department is focused on the following strategic initiatives to enhance grid security and efficiency:

1. Strengthening the security of OT systems through continuous monitoring and anomaly detection.
2. Expanding the use of AI-driven predictive maintenance to reduce downtime and optimize asset lifespan.
3. Enhancing collaboration with regulatory bodies to ensure compliance with evolving cybersecurity standards.
4. Developing an advanced threat intelligence platform to detect and mitigate cyber threats proactively.

These initiatives align with GreenGrid Energy's broader goals of achieving operational resilience, improving service reliability, and securing the smart grid ecosystem.

1.3.2 Research & Development Department

Focused on innovation and next-generation solutions, the RD department is dedicated to advancing smart grid technology, predictive analytics, and renewable energy systems through proprietary innovations. It ensures secure environments for technology development and rigorously safeguards intellectual property against cybersecurity threats.

Core Responsibilities

The main responsibilities of the department include:

- **Predictive Analytics and Algorithm Development:** Creating advanced algorithms and analytical tools designed to optimize grid performance, improve reliability, and forecast energy demands more accurately.
- **Secure Prototype Development and Testing:** Overseeing the creation and rigorous testing of technological prototypes within secure environments, mitigating cybersecurity risks and ensuring compliance with quality standards before deployment.
- **Intellectual Property Protection:** Implementing strong security controls and procedures to safeguard proprietary technology, research data, and innovations against industrial espionage, unauthorized access, and data leakage.
- **Integration with Engineering & Grid Operations:** Collaborating closely with the Engineering department to facilitate the seamless transition of validated technologies from the development stage to practical, operational environments.

Organizational Structure

The R&D department is managed by the Director of R&D, who reports directly to the Chief Technology Officer (CTO). The department structure includes dedicated specialists in algorithm development, cybersecurity and intellectual property management, prototype testing, and cross-departmental collaboration.

Future Strategic Initiatives

- **Enhanced IP Management and Security:** Strengthening procedures for intellectual property protection, including regular audits and updated cybersecurity practices.
- **Centralized Validation Platform:** Establishing a unified platform for securely validating algorithms and technologies, ensuring high standards of integrity and reliability.
- **Collaborative Innovation Partnerships:** Expanding collaboration with external technology partners and academic institutions, accelerating innovation while securely leveraging shared expertise.

1.3.3 Customer Services & Billing

All client-facing activities—such as account management, billing, and technical support—fall under this department’s purview, serving both residential and enterprise customers. Protecting personal and financial data is paramount, requiring rigorous compliance with data privacy regulations and prompt issue resolution to maintain customer satisfaction.

1.3.4 Supply Chain Management Department

The Supply Chain Management department at GreenGrid Energy plays a crucial role in supporting the company’s operational efficiency and strategic goals. Its primary responsibilities include procuring, assessing, and managing the acquisition of hardware, software, and external services necessary for the company’s operations. Given the company’s strong emphasis on cybersecurity and compliance, this department ensures that all acquired resources and services adhere to rigorous security standards and regulatory requirements.

To address the complexity of procurement and vendor management activities effectively, the Supply Chain Management department is organized with clearly defined roles under the supervision of a Supply Chain Manager, who directly reports to the COO. The internal structure of this department is as follows:

- **Supply Chain Manager:** Responsible for strategic oversight, departmental leadership, and alignment of procurement processes with organizational objectives. Coordinates overall procurement strategies and supervises team performance.
- **Hardware Procurement Specialist:** Oversees the procurement, logistics, inventory management, and verification of all physical hardware components, such as smart-grid devices, sensors, and power management equipment. Ensures hardware security integrity and vendor reliability.

- **Software Procurement Specialist:** Manages the procurement of software assets, licenses, analytics tools, and cybersecurity solutions. Collaborates closely with the CIO and CTO to confirm software solutions align with technology strategies and cybersecurity guidelines.
- **Service Procurement Specialist:** Focuses on acquiring external services critical to operations, such as consulting engagements, technical training programs, support contracts, and maintenance services. Responsible for monitoring the quality and compliance of service providers.
- **Vendor Relationship Specialist:** Dedicated to managing strategic vendor relationships across hardware, software, and services. Conducts vendor risk assessments, security audits, and compliance verifications to mitigate supply chain-related risks.

This structure ensures clear accountability, specialization of roles, and scalability to meet future operational demands. It also aligns closely with GreenGrid Energy’s cybersecurity framework by ensuring thorough vetting and continuous monitoring of all vendors and acquired resources.

The organizational hierarchy within the Supply Chain Management department is depicted below:

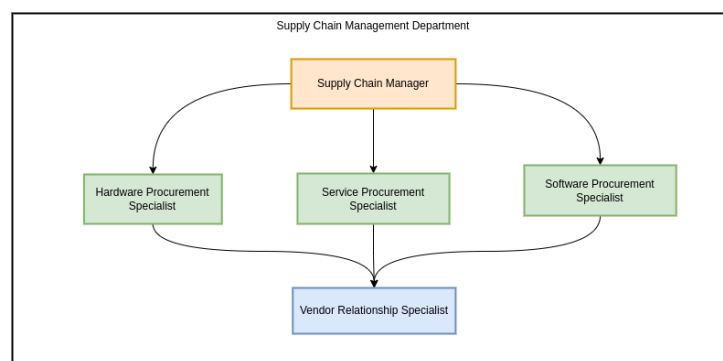


Figure 1.2: Organizational chart of Supply Chain Management Department

Through this structured organization, the Supply Chain Management department ensures efficient operations, robust security controls, and strategic alignment with GreenGrid Energy’s business objectives.

1.3.5 Human Resources (HR)

HR oversees recruitment, training, performance evaluation, and overall employee welfare. As part of the company’s broader security posture, HR also manages background checks, role-based access control, and ongoing security awareness initiatives to ensure that all staff understand and adhere to established security protocols.

1.3.6 Legal & Administration

This department ensures that GreenGrid Energy remains compliant with evolving industry regulations and standards. Core tasks include contract drafting and review, regulatory

monitoring, and oversight of administrative budgeting. By maintaining legal and procedural integrity, the Legal & Administration team supports the organization's ability to operate smoothly and avoid compliance risks.

1.4 Infrastructure and Security Context

1.4.1 Core Technologies and Systems

GreenGrid Energy's infrastructure comprises several critical technologies supporting operational excellence, security, and departmental integration.

SCADA Systems These systems allow real-time control and monitoring of grid equipment, essential for the reliability and stability of energy distribution operations.

Hybrid Cloud Platforms (AWS/Azure) Offer scalable computing, secure data storage, advanced analytics, and support for IoT device management, facilitating innovation and departmental collaboration.

Edge Computing Provides local data processing capabilities near physical assets, ensuring low latency and rapid response for critical grid management tasks.

Microsoft 365 The primary platform for internal communication, collaboration, and productivity across all company departments.

SAP Enterprise Resource Planning (ERP) Integrates business-critical functions such as procurement, inventory management, customer services, financial oversight, and regulatory compliance.

1.4.2 Network Topology

GreenGrid Energy maintains two distinct networks to segregate operational and corporate functions securely:

- **OT Network:** Hosts grid-specific operations, including SCADA systems and field-deployed IoT devices.
- **IT Network:** Manages corporate services such as ERP systems, collaboration tools, and human resources applications.

Secure segmentation between the OT and IT networks is essential to safeguard critical infrastructure operations.

1.4.3 Threat Landscape

The primary cybersecurity threats facing GreenGrid Energy include:

- **Nation-State Actors:** Target critical infrastructure for strategic objectives and disruption.

- **APTs:** Sophisticated attackers leveraging vulnerabilities in IoT and grid-related technologies.
- **Supply Chain Risks:** Compromise of hardware or software components through third-party suppliers.

1.4.4 Technology and Department Association

The following table associates each core technology with its primary departmental users, highlighting responsibility and ensuring clear governance:

Table 1.1: Core Technologies and Associated Departments

Technology/System	Primary Department(s)
SCADA Systems	Engineering & Grid Operations
Hybrid Cloud Platforms (AWS/Azure)	IT, RD
Edge Computing	Engineering & Grid Operations, RD
Microsoft 365	All Departments
SAP ERP	Supply Chain, Customer Services, Legal & Administration, Human Resources (HR)
OT Network	Engineering & Grid Operations
IT Network	IT, Legal & Administration, HR

This clear and organized mapping ensures effective oversight, accountability, and management of cybersecurity risks across the company's operational infrastructure.

Chapter 2

Scope of the ISMS

2.1 Scope of the ISMS

Aligned with ISO/IEC 27001 Clause 4.3 guidelines,² this chapter outlines the scope of GreenGrid Energy’s ISMS, identifying stakeholders, IT infrastructure, key business processes, associated data, and explicit ISMS boundaries.

2.1.1 Organizational Stakeholders

GreenGrid Energy’s stakeholders, as defined by ISO/IEC 27001, include both internal and external entities that influence or are impacted by the organization’s security practices.⁴

Table 2.1: Stakeholders and ISMS Interaction

Stakeholder Group	Interaction with the ISMS
Executive Management and Board	Provide strategic oversight, allocate resources, approve ISMS scope, and review security performance.
IT Department	Implement and maintain technical security controls; daily management of the ISMS infrastructure.
Department Heads and Employees	Comply with ISMS policies, handle information securely, report incidents, and participate in risk assessments.
Customers and Clients	Expect protection of data confidentiality, integrity, and availability as part of service agreements.
Suppliers and Third-Party Providers	Comply with contractual security requirements to ensure the security of GreenGrid data processed externally.
Regulators and Authorities	Expect adherence to industry regulations and may audit ISMS practices and compliance.
Certifying Bodies/Auditors	Evaluate and validate compliance with ISO/IEC 27001 through periodic certification audits.

2.1.2 Shared IT Infrastructure and Systems

GreenGrid Energy employs a centrally managed IT infrastructure shared by multiple departments. This infrastructure includes:

- **Network Infrastructure:** Company-wide network including Local Area Network (LAN), secure Wi-Fi, and Virtual Private Network (VPN) for remote employees.
- **Server and Cloud Systems (AWS/Azure):** Hosting internal applications, databases, and departmental services.
- **Enterprise Applications:** Microsoft 365, SAP ERP, and Customer Relationship Management (CRM) software supporting business operations and collaboration.
- **User Devices:** Managed desktop computers, laptops, and mobile devices.
- **Data Storage and Backup Systems:** Centralized data repositories and backup solutions.
- **Communication and Collaboration Tools:** Email systems, instant messaging platforms, video conferencing, and intranet portals.

Specific security policies and controls regarding these technologies are detailed in subsequent chapters.

2.1.3 Business Processes, Data, and Security Risks by Department

The following table summarizes each department's core business processes, data handled, and security risks.

Department	Key Processes and Data	Security Risks
Engineering & Operations	Real-time grid operations (SCADA data, logs, asset management)	Unauthorized access, service disruptions, data integrity threats
Research & Development (R&D)	Proprietary research, predictive algorithms, software code	Intellectual property theft, data leakage, espionage
Customer Services	Client contracts, billing data, CRM, customer PII	Privacy breaches, financial fraud, unauthorized data disclosure
Finance	Financial management (budgeting, transactions, payroll, ERP financial module)	Financial fraud, phishing attacks, unauthorized access, data tampering

Supply Chain Management	Procurement processes (vendor contracts, inventory data, supplier credentials)	Supply chain compromise, counterfeit hardware/software, insecure vendor access
Human Resources	Employee management (personal records, payroll data, performance data)	Unauthorized disclosure, insider threats, privacy breaches
IT Department	Infrastructure management (network devices, servers, endpoint devices, IAM systems, incident response data)	System compromise, configuration errors, misuse of admin privileges
Sales and Marketing	Customer relationship management (CRM), market data, public web resources	Unauthorized access to client data, reputation damage, phishing/malware attacks

2.1.4 ISMS Boundaries and Exclusions

The ISMS boundaries include:

- Internal IT and OT networks, including SCADA and enterprise systems used by the Supply Chain Management, Customer Services & Billing, and Research & Development departments.
- Data processing within cloud environments (e.g., AWS or Azure) that is generated or consumed by the Supply Chain Management, Customer Services & Billing, and Research & Development departments.
- Procurement processes and vendor management.
- Employee data, access management, and training processes.

Explicit exclusions from the ISMS scope include:

- Third-party systems fully managed externally, where GreenGrid has no direct control.
- Personal employee devices not centrally managed by the organization.
- Physical security at externally managed premises (e.g., leased data centers).
- Separate subsidiaries or partner organizations.

These exclusions are justified by the lack of direct administrative oversight or practical manageability; any associated risks are mitigated through contractual obligations and vendor assessments.¹

Bibliography

- [1] Advisera. All you need to know about setting the iso 27001 scope. <https://advisera.com/27001academy/knowledgebase/how-to-define-the-isms-scope/>, 2023. Accessed: 2024-03-10.
- [2] ISO/IEC. Iso/iec 27001:2022 - information security management systems. <https://www.iso.org/standard/54534.html>, 2022. Accessed: 2024-03-10.
- [3] Portugal 2020. Portugal 2020 – European Structural and Investment Funds, 2020. Accessed: 2025-03-07.
- [4] High Table. Iso 27001 scope statement beginner’s guide. <https://hightable.io/iso-27001-scope-statement/>, 2023. Accessed: 2024-03-10.